

SPORTS FACILITY BOOKING SYSTEM

Laboratory Exercise: Secure Web System — Sessions, Cookies, Validation, and Access Restrictions

System Name: Sports Facility Booking System

Assigned Topic: Sports Facility Booking

Group / Section: Group 7

Members:

MA. IRENE ADEL

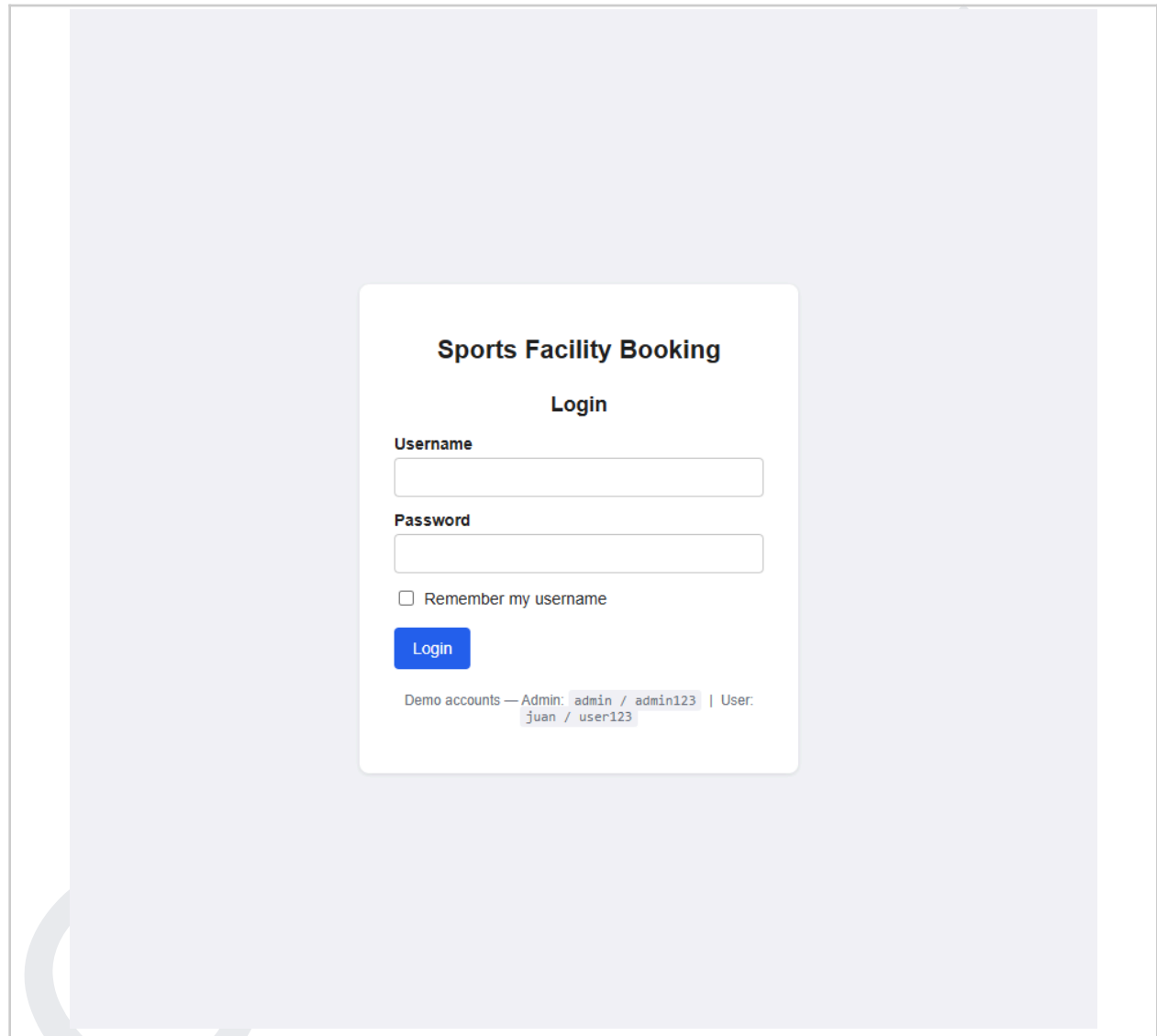
AGATHA FEI PELAYO

MARI ALESSANDRAE ROSERO

MICO ANGELO TAZARTE

Security Feature 1: Login Validation

The login page requires a username and password, verifies the account exists, and checks the password. On any failure, the system shows a single generic message, "Invalid username or password." without revealing which field was incorrect, exactly as the activity sheet requires.



The image shows a login form for a 'Sports Facility Booking' system. The form is centered on a light gray background. It includes fields for 'Username' and 'Password', a 'Remember my username' checkbox, and a blue 'Login' button. Below the button, there is a line of text providing demo account credentials: 'Demo accounts — Admin: admin / admin123 | User: juan / user123'. The 'Admin' part is highlighted in light blue, and the 'User' part is highlighted in light gray.

Sports Facility Booking

Login

Username

Password

☐ Remember my username

Login

Demo accounts — Admin: admin / admin123 | User: juan / user123

The image shows a login form for a 'Sports Facility Booking' system. The form is centered on a light gray background. It features a title 'Sports Facility Booking' and a subtitle 'Login'. Below the subtitle, there is a red error message box that says 'Invalid username or password.'. Underneath the error message, there are two input fields: 'Username' and 'Password'. Below the 'Password' field, there is a checkbox labeled 'Remember my username'. A blue 'Login' button is positioned below the checkbox. At the bottom of the form, there is a section for 'Demo accounts' with the following text: 'Admin: admin / admin123 | User: juan / user123'.

Sports Facility Booking

Login

Invalid username or password.

Username

Password

☐ Remember my username

Login

Demo accounts — Admin: admin / admin123 | User: juan / user123

The login form also includes basic brute-force protection: after repeated failed attempts, the form is temporarily disabled with the message "Too many failed login attempts. Please wait a moment before trying again." This goes beyond the minimum requirement and supports Security Feature 10 (basic security practices).

Sports Facility Booking

Login

Too many failed login attempts. Please wait a moment before trying again.

Username

Password

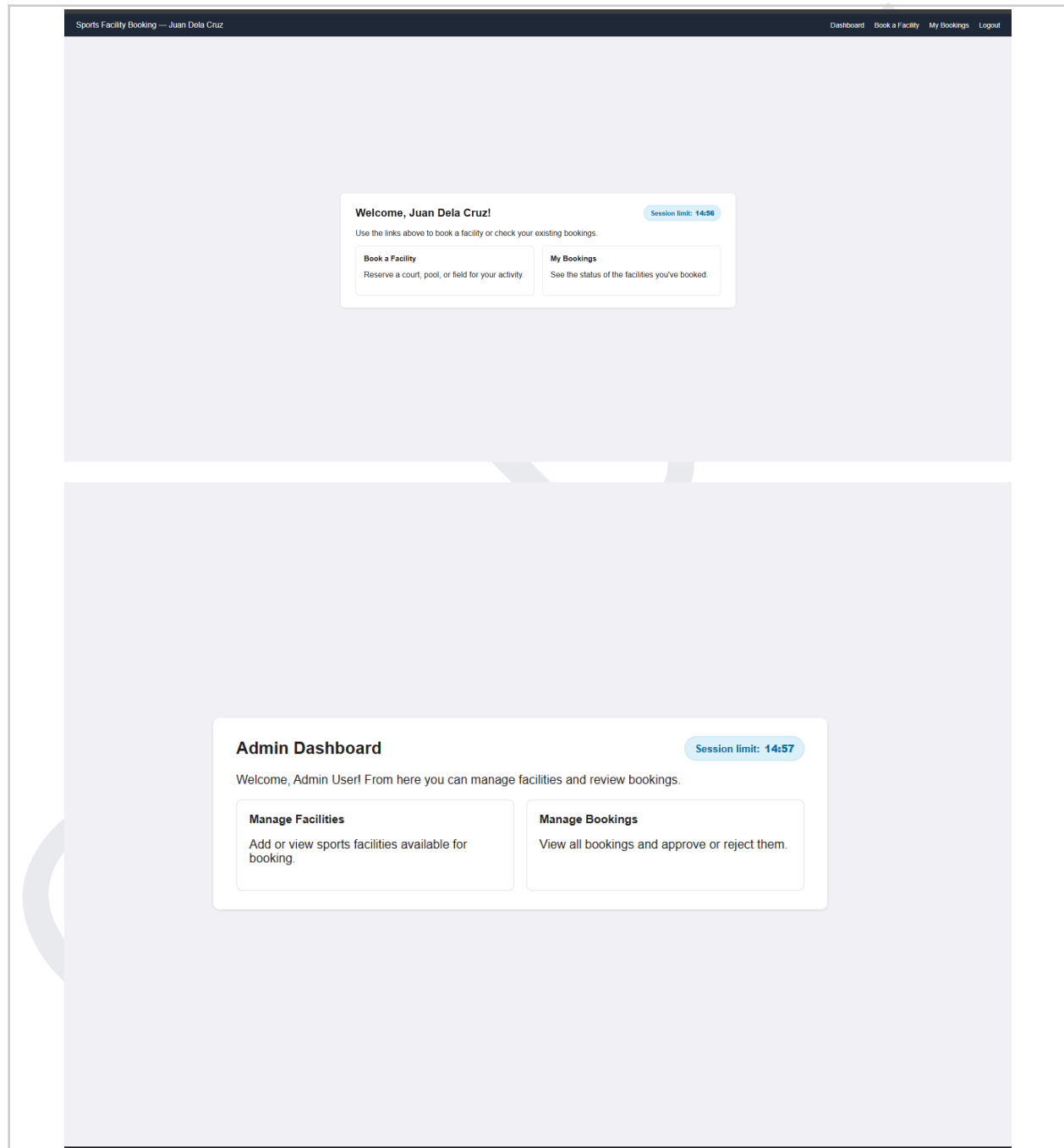
☐ Remember my username

Login

Demo accounts — Admin: admin / admin123 | User:
juan / user123

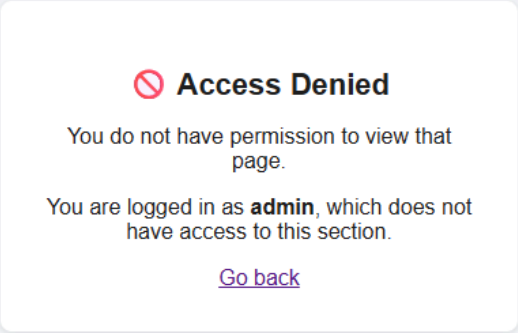
Security Feature 2 - PHP Sessions

On a successful login, the system creates a session that stores the logged-in username and role. Every subsequent page reads this session to personalize the view ("Welcome, Juan Dela Cruz!") and to decide what that user is allowed to do.



Security Feature 3 - Session-Based Page Restrictions

Every dashboard, booking, and admin page is protected on the server: a request from a visitor with no active session is redirected back to the login page instead of showing the page content.

A white rectangular box with rounded corners and a subtle drop shadow, centered on a light gray background. It contains an "Access Denied" message.

Access Denied

You do not have permission to view that page.

You are logged in as **admin**, which does not have access to this section.

[Go back](#)

Security Feature 4 - Role-Based Access Control

Regular Users and Administrators see different navigation and different functions. The Manage Facilities and Manage Bookings pages are only reachable — and only usable — by an Administrator account.

All Bookings

Session limit: 14:59

ID	User	Facility	Date	Time	Participants	Status	Action
1	Juan	Swimming Pool	2026-09-17	3:00 PM - 5:00 PM	20	Approved	—
2	Juan	Mico	2026-09-17	10:00 AM - 12:00 PM	20	Pending	Approve Reject
3	Juan	Mico	2026-09-17	10:00 AM - 12:00 PM	20	Pending	Approve Reject
4	Juan	Mico	2026-09-17	10:00 AM - 12:00 PM	20	Pending	Approve Reject
5	Juan	Basketball Court	2026-09-17	8:00 AM - 10:00 AM	5	Rejected	—

GRO

Manage Facilities

Session limit: 14:58

Add Facility

Facility Name

Capacity

Rate per Hour (P)

Add Facility

Existing Facilities

ID	Name	Capacity	Rate/Hour
1	Basketball Court	20	P500.00
2	Volleyball Court	16	P350.00
3	Swimming Pool	30	P800.00
4	Tennis Court	4	P400.00
5	Mico	10	P200.00

Manage Facilities

Session limit: 14:59

Facility added successfully.

Add Facility

Facility Name

Capacity

Rate per Hour (P)

Add Facility

Existing Facilities

ID	Name	Capacity	Rate/Hour
1	Basketball Court	20	P500.00
2	Volleyball Court	16	P350.00
3	Swimming Pool	30	P800.00
4	Tennis Court	4	P400.00
5	Mico	10	P200.00
6	test	200	P300.00

 Access Denied

You do not have permission to view that page.

You are logged in as **user**, which does not have access to this section.

[Go back](#)

Security Feature 5 - Cookies

The login form includes a "Remember my username" checkbox. When checked, only the username is stored in a cookie; the password is never stored in a cookie.

Sports Facility Booking

Login

You have been logged out.

Username

Password

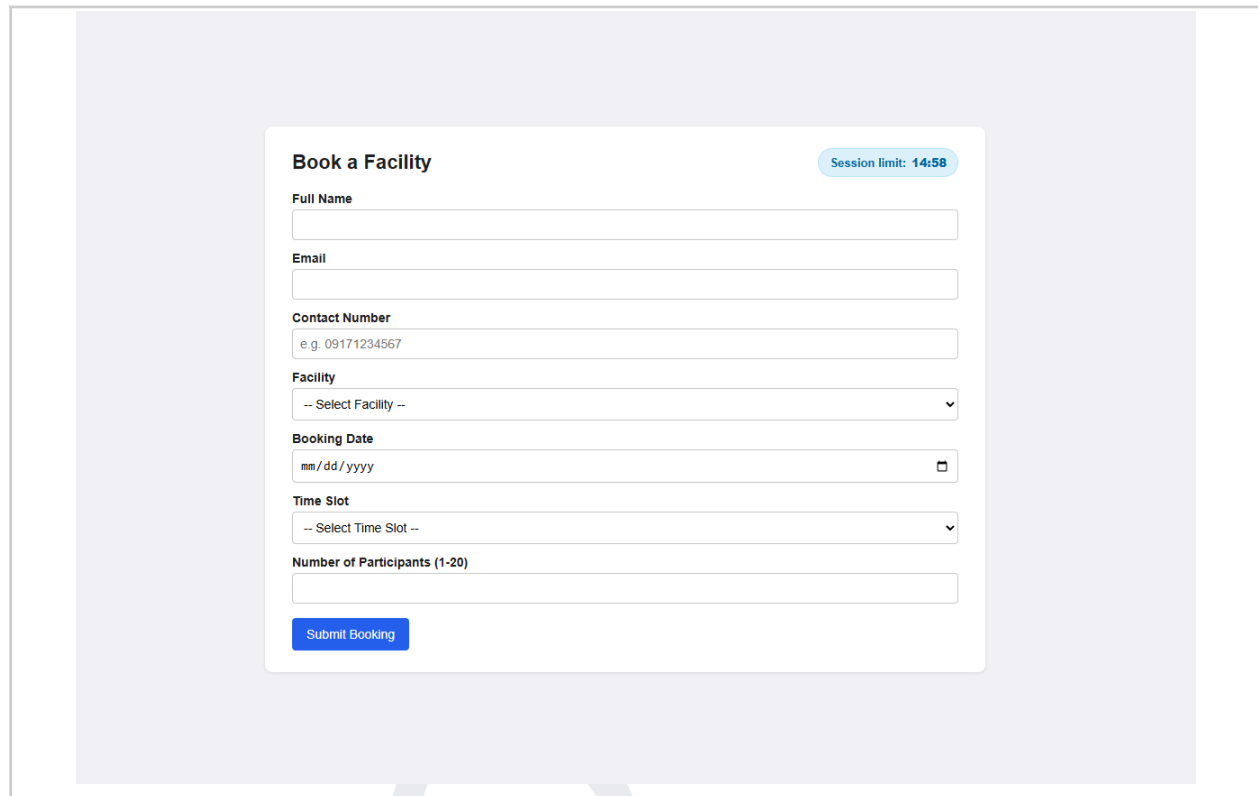
☒ Remember my username

Login

Demo accounts — Admin: admin / admin123 | User: juan / user123

Security Feature 6 - Form Validation (Book a Facility)

The booking form is the system's main transaction form. All fields are validated on the server before a booking is created: required fields, a valid contact number, a valid facility and time slot selection, and a participant count within the allowed range (1–20).



The screenshot displays a web form titled "Book a Facility" set against a light purple background. A blue badge in the top right corner of the form indicates a "Session limit: 14:58". The form contains the following fields and controls:

- Full Name:** A text input field.
- Email:** A text input field.
- Contact Number:** A text input field with a placeholder example "e.g. 09171234567".
- Facility:** A dropdown menu with the placeholder text "-- Select Facility --".
- Booking Date:** A date picker field showing the format "mm / dd / yyyy".
- Time Slot:** A dropdown menu with the placeholder text "-- Select Time Slot --".
- Number of Participants (1-20):** A text input field.
- Submit Booking:** A blue button at the bottom of the form.

A large, light gray "GRO" watermark is oriented diagonally across the lower half of the image.

Book a Facility

Session limit: 14:59

Contact number is required.

Full Name

Mico Angelo C. Tazarte

Email

micotazarte@gmail.com

Contact Number

e.g. 09171234567

Facility

Basketball Court (P500.00/hr)

Booking Date

09/17/2026

Time Slot

8:00 AM - 10:00 AM

Number of Participants (1-20)

5

Submit Booking

Basketball Court (P500.00/hr)

Booking Date

09/17/2026

September 2026 ▾



Su	Mo	Tu	We	Th	Fr	Sa
30	31	1	2	3	4	5
6	7	8	9	10	11	12
13	14	15	16	17	18	19
20	21	22	23	24	25	26
27	28	29	30	1	2	3
4	5	6	7	8	9	10

Clear

Today

Book a Facility

Session limit: 14:37

Full Name

Mico Angelo C. Tazarte

Email

micotazarte@gmail.com

Contact Number

09457786367

Facility

Basketball Court (P500.00/hr)

Booking Date

09/17/2026

Time Slot

8:00 AM - 10:00 AM

Number of Participants (1-20)

5

Submit Booking

Book a Facility

Session limit: 14:59

Booking submitted! It is now pending admin approval.

Full Name

Email

Contact Number

e.g. 09171234567

Facility

-- Select Facility --

Booking Date

mm/dd/yyyy

Time Slot

-- Select Time Slot --

Number of Participants (1-20)

Submit Booking

Book a Facility

Session limit: 14:59

Full name is required.

Full Name

Email

micotazarte@gmail.com

Contact Number

09457786367

Facility

Basketball Court (₱500.00/hr)



Booking Date

09/16/2026



Time Slot

10:00 AM - 12:00 PM



Number of Participants (1-20)

20

Submit Booking

Book a Facility

Session limit: 15:00

Invalid email address.

Full Name

Mico Angelo C. Tazarte

Email

micotazartegmail.com

Contact Number

09457786367

Facility

Basketball Court (P500.00/hr)



Booking Date

09/16/2026



Time Slot

10:00 AM - 12:00 PM



Number of Participants (1-20)

20

Submit Booking

Book a Facility

Session limit: 15:00

Number of participants must be between 1 and 20.

Full Name

Mico Angelo C. Tazarte

Email

micotazarte@gmail.com

Contact Number

09457786367

Facility

Basketball Court (P500.00/hr)

Booking Date

09 / 16 / 2026

Time Slot

10:00 AM - 12:00 PM

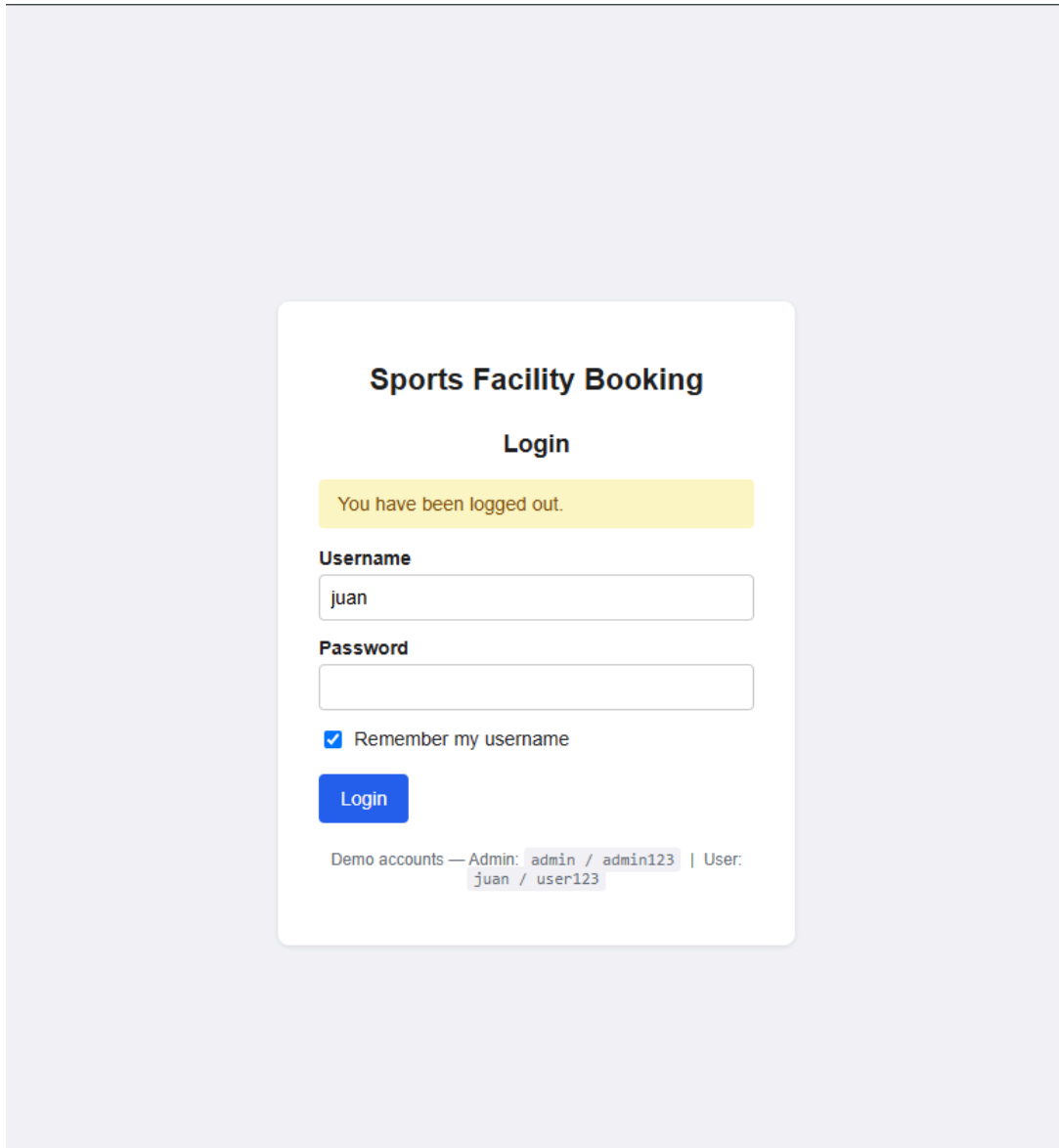
Number of Participants (1-20)

25

Submit Booking

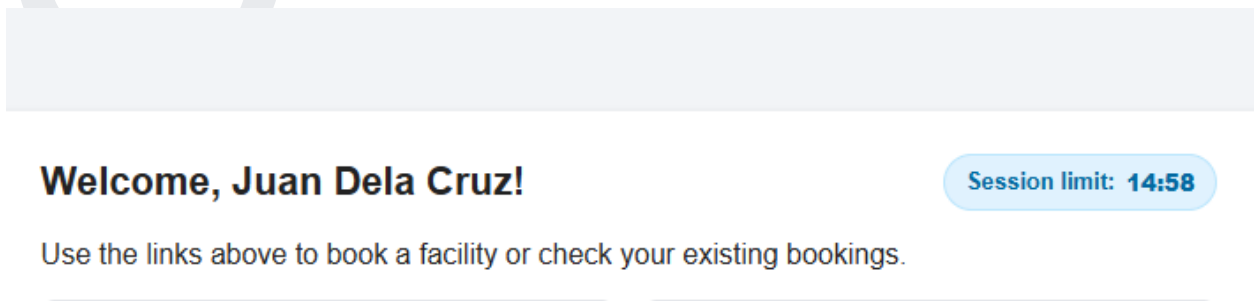
Security Feature 7 - Logout

A Logout link is available in the navigation bar for both roles. Logging out destroys the session; if the user then presses Back and reloads a protected page, they are redirected to the login page rather than seeing cached protected content.



Security Feature 8 - Session Timeout

Every protected page displays a live "Session limit" countdown (see the top-right badge in Figures 3-14, e.g. "Session limit: 14:59"). When the countdown reaches zero, the session is expected to expire and the user is returned to the login page.



Security Feature 9 - Unauthorized Access Page

A dedicated Access Denied page is expected to be shown whenever a logged-in user of the wrong role requests a page they are not permitted to view.



Access Denied

You do not have permission to view that page.

You are logged in as **user**, which does not have access to this section.

[Go back](#)

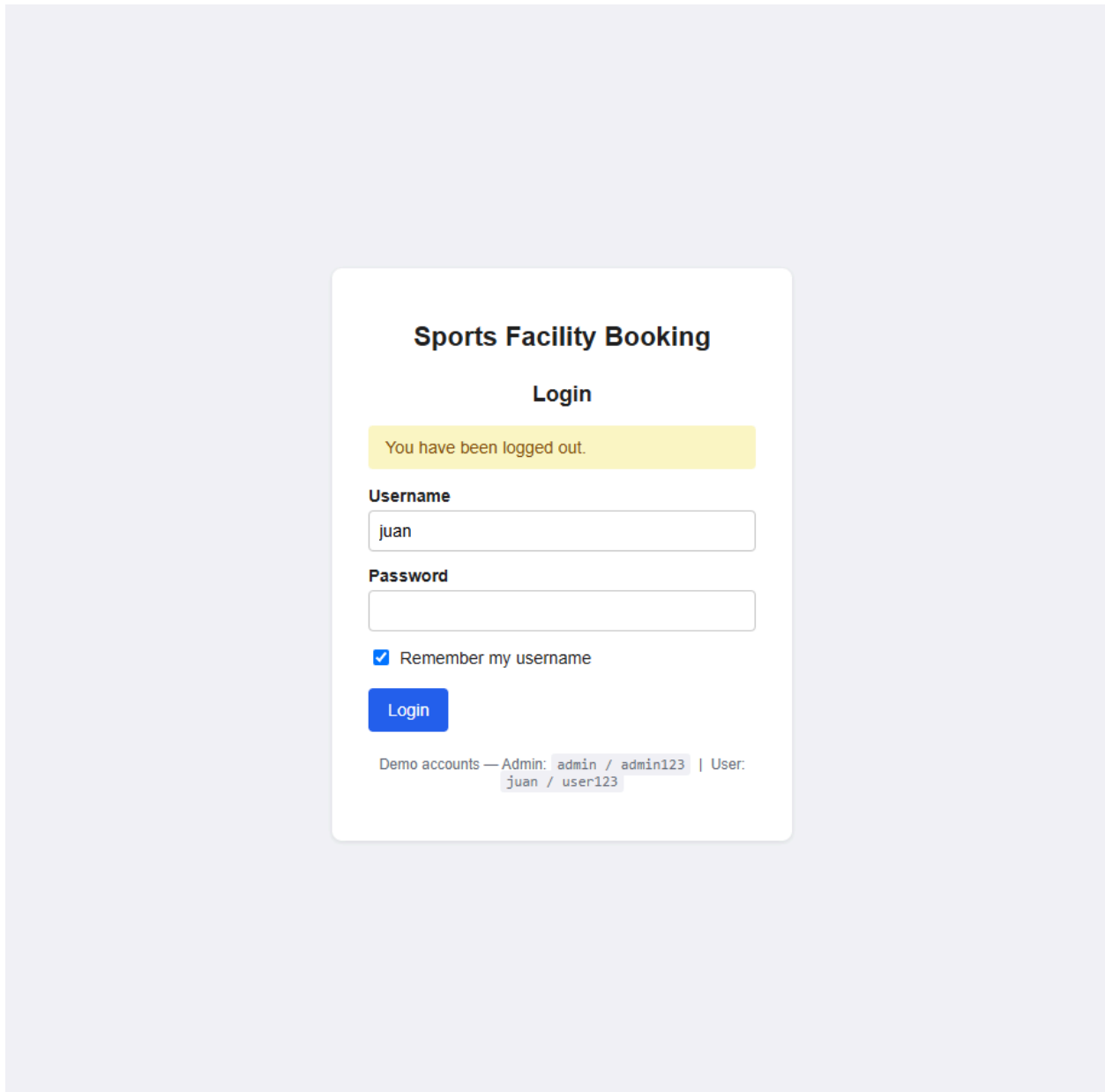
Basic Web Security Practices

- Login rate-limiting after repeated failed attempts
- Generic, non-revealing error message on failed login
- Server-side re-validation of every form field, not just HTML5 client-side hints.
- Session-based authentication with a visible, enforced expiry countdown.

```
includes > users_data.php
1  <?php
2  // =====
3  // Programmer Names: Agatha Fei Pelayo, Ma Irene Adel, Mari Alessandreae Rosero, Mico Angelo Tazarte
4  // DEMO ACCOUNTS
5  // For a real system these would be rows in a database table,
6  // with the password_hash column already stored. Here we hash
7  // the demo passwords on the fly just so this works out of the
8  // box with zero setup.
9  //
10 // Demo login credentials:
11 // Admin -> username: admin password: admin123
12 // User -> username: juan password: user123
13 // =====
14
15 $USERS = [
16     'admin' => [
17         'name' => 'Admin User',
18         'password_hash' => password_hash('admin123', PASSWORD_DEFAULT),
19         'role' => 'admin',
20     ],
21     'juan' => [
22         'name' => 'Juan Dela Cruz',
23         'password_hash' => password_hash('user123', PASSWORD_DEFAULT),
24         'role' => 'user',
25     ],
26 ];
27
```

Cookie Test

Steps: (1) enter username, (2) check Remember my username, (3) login, (4) logout, (5) return to login page. Expected: username field is pre-filled, password field remains blank.



The screenshot shows a web application titled "Sports Facility Booking" with a "Login" section. A yellow message box at the top states "You have been logged out." Below this, the "Username" field is pre-filled with "juan". The "Password" field is empty. A checkbox labeled "Remember my username" is checked. A blue "Login" button is present. At the bottom, demo accounts are listed: "Admin: admin / admin123" and "User: juan / user123".

Sports Facility Booking

Login

You have been logged out.

Username

juan

Password

☐ Remember my username

Login

Demo accounts — Admin: admin / admin123 | User: juan / user123

Session Timeout and Logout

Sports Facility Booking

Login

Username

juan

Password

☒ Remember my username

Login

Demo accounts — Admin: admin / admin123 | User:
juan / user123

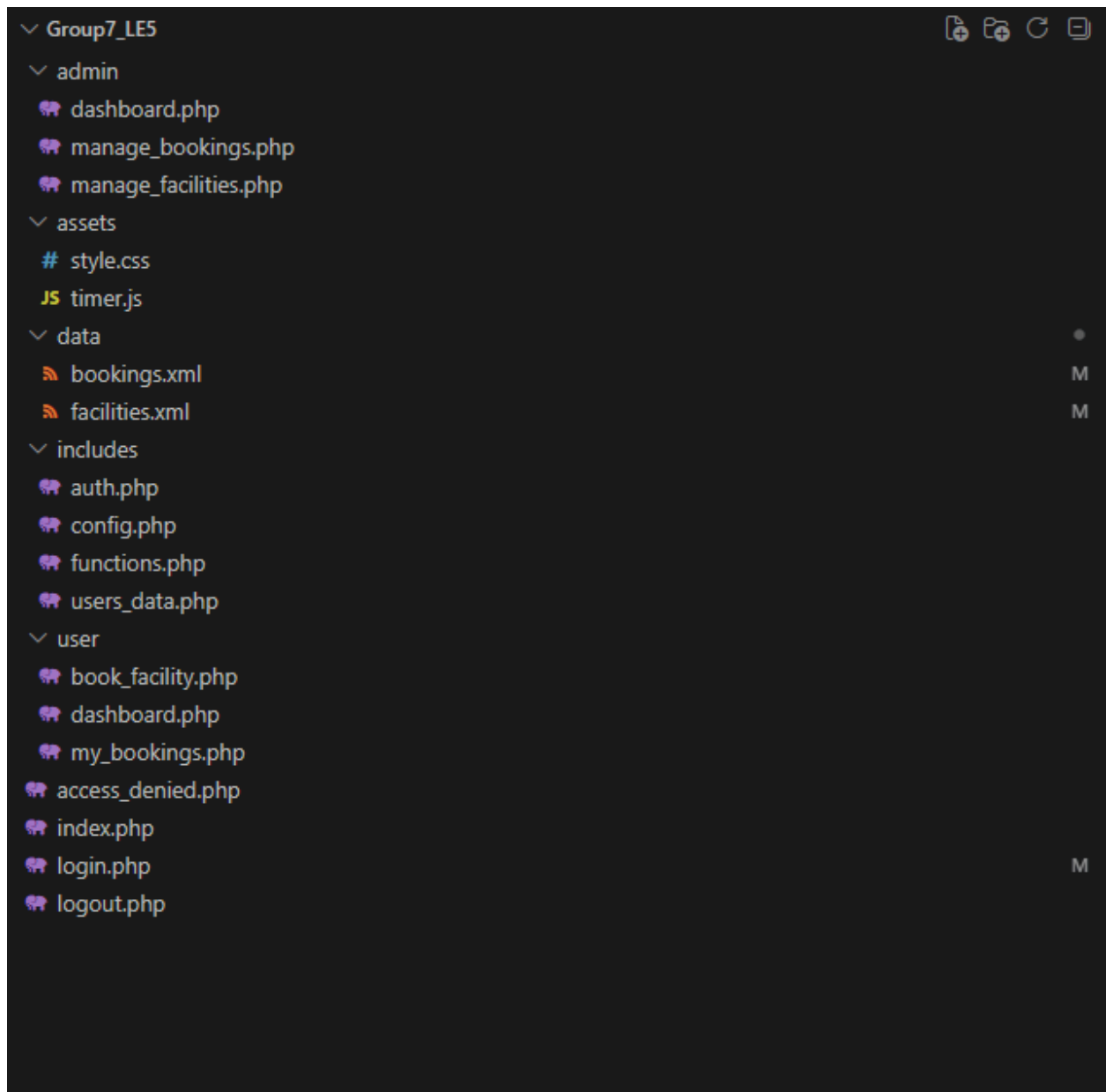
Final Security Testing Checklist

As required by Section 17 of the activity sheet, before submission:

#	Security Test	Pass / Fail
1	Empty login username is rejected	Pass
2	Empty login password is rejected	Pass
3	Incorrect login is rejected	Pass
4	Successful login creates a session	Pass
5	Guest cannot access protected page	Pass
6	Regular user cannot access admin page	Pass
7	Admin can access admin page	Pass
8	Cookie remembers username only	Pass
9	Form validates required fields	Pass
10	Invalid email is rejected	Pass
11	Invalid numeric input is rejected	Pass
12	Logout destroys session	Pass
13	Protected page cannot be accessed after logout	Pass
14	Session timeout works	Pass
15	Unauthorized access displays appropriate message	Pass

System Structure

File / Folder Structure



XML Data Source

As required by the activity sheet, the system uses XML as its data source (. for user accounts and facility/booking records).

Explorer

Open Editors

- Login - Sports Facility Bookin... http://localhost:8000/login.php
- bookings.xml data M

Group7_LE5

- admin
- dashboard.php
- manage_bookings.php
- manage_facilities.php
- assets
- style.css
- timer.js
- data
 - bookings.xml M
 - facilities.xml M
- includes
 - auth.php
 - config.php
 - functions.php
 - users_data.php
- user
 - book_facility.php
 - dashboard.php
 - my_bookings.php
 - access_denied.php
 - index.php
 - login.php M
 - logout.php

Outline

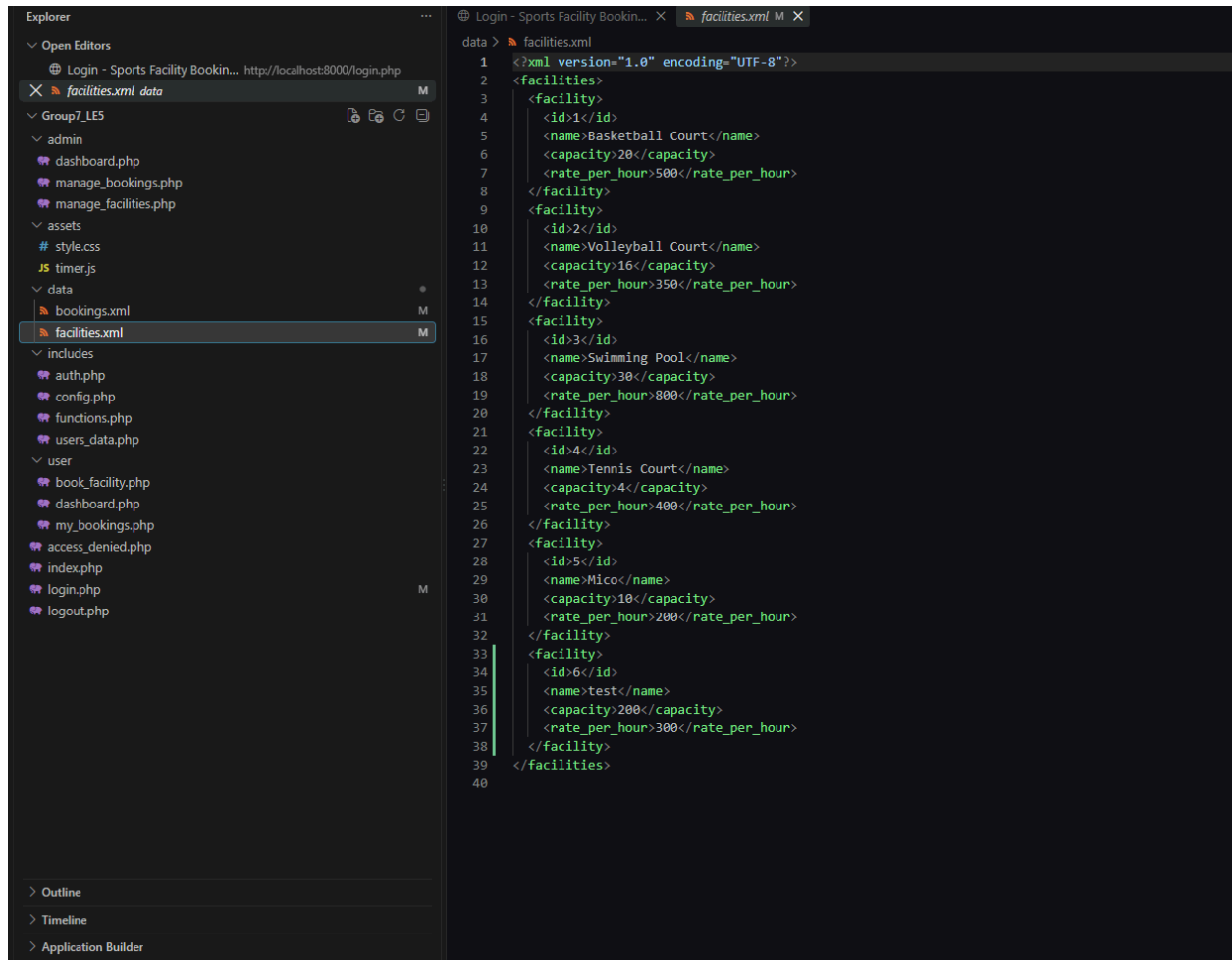
Timeline

Application Builder

Login - Sports Facility Bookin... X bookings.xml M X

data > bookings.xml

```
1 <?xml version="1.0" encoding="UTF-8"?>
2 <bookings>
3   <booking>
4     <id>1</id>
5     <username>juan</username>
6     <full_name>Mico Angelo C. Tazarte</full_name>
7     <email>micotazarte@gmail.com</email>
8     <contact>09457786367</contact>
9     <facility>Swimming Pool</facility>
10    <date>2026-09-17</date>
11    <time_slot>3:00 PM - 5:00 PM</time_slot>
12    <participants>20</participants>
13    <status>approved</status>
14    <created_at>2026-09-16 06:06:30</created_at>
15  </booking>
16  <booking>
17    <id>2</id>
18    <username>juan</username>
19    <full_name>Mico Angelo C. Tazarte</full_name>
20    <email>micotazarte@gmail.com</email>
21    <contact>09457786367</contact>
22    <facility>Mico</facility>
23    <date>2026-09-17</date>
24    <time_slot>10:00 AM - 12:00 PM</time_slot>
25    <participants>20</participants>
26    <status>pending</status>
27    <created_at>2026-09-16 06:57:42</created_at>
28  </booking>
29  <booking>
30    <id>3</id>
31    <username>juan</username>
32    <full_name>Mico Angelo C. Tazarte</full_name>
33    <email>micotazarte@gmail.com</email>
34    <contact>09457786367</contact>
35    <facility>Mico</facility>
36    <date>2026-09-17</date>
37    <time_slot>10:00 AM - 12:00 PM</time_slot>
38    <participants>20</participants>
39    <status>pending</status>
40    <created_at>2026-09-16 06:57:47</created_at>
41  </booking>
42  <booking>
43    <id>4</id>
44    <username>juan</username>
45    <full_name>Mico Angelo C. Tazarte</full_name>
46    <email>micotazarte@gmail.com</email>
47    <contact>09457786367</contact>
48    <facility>Mico</facility>
49    <date>2026-09-17</date>
```



Accounts Used for Testing

Role	Username	Password
Administrator	admin	admin123
Regular User	juan	user123

Member Contributions

Member	Contribution Rating (10/10)
MA. IRENE ADEL	10
AGATHA FEI PELAYO	10
MARI ALESSANDRAE ROSERO	10
MICO ANGELO TAZARTE	10